

BEFORE Placeholder

AFTER

# Logging & Auditability Control Baseline (Tiered)

Document classification: Internal

Baseline owner: Security Engineering/Architecture

Version: 0.1

Effective date: \_\_\_\_\_

Review cadence: Annually

## 1. Purpose

Define minimum logging and auditability controls for third parties, including what must be logged, retention expectations, export mechanisms, and validation steps to prove controls are in place.

## 2. Scope

Applies to suppliers that:

- provide a tenant/admin console, and/or
- authenticate users (SSO/local), and/or
- integrate via API/agents/connectivity, and/or
- process organisational data.

## 3. Control statements (tiered)

### 3.1 Tier Critical (Tier 1) — MUST controls

Critical suppliers MUST:

1. **Enable audit logs** for:

- authentication events (success/failure; MFA events where available)
- administrative actions (role changes, policy/config changes, security setting changes)
- integration activity (API calls; especially write actions) where applicable
- data export/access events where available for sensitive datasets

2. **Prevent or tightly control audit disablement:**

- only restricted admin roles can change logging settings
- logging/retention changes are auditable

3. **Provide log accessibility:**

- logs retrievable via export, API pull, or forwarding mechanism
- method documented and tested

4. **Retain logs** for an agreed period sufficient for assurance and investigations (per organisational standard or contracted requirement).

5. **Support incident investigations:**

- ability to provide relevant logs within agreed timelines during an incident.

6. **Documented ownership:**

- identify who administers logging and who can request logs.

Critical suppliers SHOULD:

- support near-real-time forwarding to organisation-controlled logging where feasible
- provide alerting capabilities for high-risk events (or allow customer-side alerting through exported logs)
- support immutable storage controls on the receiving platform (where available)

## 3.2 Tier Important (Tier 2) — MUST controls

Important suppliers MUST (where the service supports it):

- provide audit logs for admin actions and authentication events
- define retention and retrieval method
- restrict who can change logging settings

Important suppliers SHOULD:

- provide API activity logs where integrations exist
- provide export capability suitable for periodic reviews and investigations

### 3.3 Tier Low (Tier 3) — proportionate controls

Low suppliers SHOULD:

- confirm whether audit logs exist and how they can be exported if needed
- provide incident contact and cooperation for investigations

## 4. Minimum log events (reference catalogue)

Capture where available, prioritised by risk: Authentication:

- login success/failure
- MFA success/failure (if exposed)
- password resets (if applicable)
- SSO configuration changes

Admin and configuration:

- user creation/deletion
- role assignments and privilege escalations
- changes to security policies (MFA/SSO/logging/retention)
- API credential creation/rotation/revocation

Integration/API:

- token issuance/refresh (where available)
- API calls (endpoint/object metadata)
- write actions (create/update/delete), ideally with actor identity and timestamp

Data access/export:

- exports/downloads
- access to sensitive reports/datasets (where supported)

Connectivity:

- VPN tunnel up/down
- route changes
- firewall allow/deny summaries (where applicable)

## 5. Retention guidance (set to organisational standard)

Record the organisational log retention requirement here:

- Tier Critical: \_\_\_\_\_ months (recommended  $\geq 12$  months, or per internal standard)
- Tier Important: \_\_\_\_\_ months (recommended  $\geq 6$  months, or per internal standard)
- Tier Low: \_\_\_\_\_ months (as needed)

Note: if supplier cannot meet retention, a documented mitigation or exception is required for Critical suppliers.

## 6. Export patterns (acceptable mechanisms)

Select one per supplier:

- Push/Forward (preferred for Critical where feasible)
- Pull/API retrieval
- Manual export (acceptable only with documented constraints; Critical requires compensating controls)

Reference implementation guidance:

- See ``integration-patterns/09-pattern-logging-and-audit-export.md``

## 7. Validation steps (how to prove it)

For each supplier, record evidence location and complete the checks below.

## 7.1 Enablement checks

- ☐ Audit logging enabled in tenant/admin console (screenshot or admin setting export)
- ☐ Log categories enabled (admin/auth minimum)
- ☐ Logging settings change is restricted to named admin roles

Evidence location:

---

## 7.2 Retrieval checks

- ☐ Demonstrate log retrieval method works (sample export/API call/forward test)
- ☐ Confirm time window coverage (no gaps for last 7 days)
- ☐ Confirm timestamps include time zone or UTC

Evidence location:

---

## 7.3 Retention checks

- ☐ Retention setting confirmed (screenshot/config statement)
- ☐ Retention meets required period or exception exists
- ☐ Procedure exists to preserve logs for investigations (if needed)

Evidence location:

---

## 7.4 Integrity and access control checks

- ☐ Log access restricted to least-privilege roles
- ☐ Attempts to disable logging/retention are logged (test where feasible)
- ☐ Admin role assignments are audited (test where feasible)

Evidence location:

---

## 7.5 Integration-specific checks (if API write or privileged access exists)

☐ API write actions are logged and attributable to integration identity

☐ Admin role changes are logged and attributable

☐ Alerting/detection approach documented for high-risk events

Evidence location:

---

## 8. Exceptions

Any deviation from Tier Critical MUST requirements requires:

- exception request with compensating controls (e.g., enhanced access restrictions, additional monitoring, shorter exposure windows)
- expiry date and remediation plan

## 9. Sign-off (per supplier)

Supplier: \_\_\_\_\_ Service: \_\_\_\_\_ Tier: ☐ Critical ☐

Important ☐ Low

Security Engineering/Architecture (role title): \_\_\_\_\_ Date: \_\_\_\_\_ IT/Platform Owner

(role title): \_\_\_\_\_ Date: \_\_\_\_\_ Business Service Owner (role title):

\_\_\_\_\_ Date: \_\_\_\_\_